

CyberDefense Pro 2.0

2.1.3 Industry Standard Publishers Facts

This lesson covers the following topics:

- The relationship between regulations and standards
- National Institute of Standards and Technology (NIST)
- Internal Organization for Standardization

The Relationship Between Regulations and Standards

Regulations and standards are tightly integrated. Whereby regulations describe legal requirements and ramifications, compliance details are often provided in prescriptive form within a standard.

Two very prominent and widely recognized organizations responsible for publishing and maintaining standards are ISO and NIST. ISO and NIST devote considerable time and effort to developing best practices. Their standards represent the collective effort of many industries, thought leaders, and practicing experts. ISO and NIST do not create laws and regulations; instead, laws and regulations identify a requirement to implement the best practice guidance authored by these agencies.

For example, the authority to require U.S. federal agencies to implement a comprehensive information security program is detailed in the Federal Information Security Modernization Act (FISMA.) FISMA is a detailed legislation that describes many far-reaching requirements for governance, risk, and compliance. However, many NIST publications are referenced regarding how an organization will be measured against these requirements. Two of the NIST standards referenced in FISMA include SP 800-53 - "Security and Privacy Controls for Information Systems and Organizations" and FIPS 199 - Federal Information Processing Standards (FIPS) Publication 199 "Standards for Security Categorization of Federal Information and Information Systems."

National Institute of Standards and Technology (NIST)

The National Institute of Standards and Technology (NIST) is a nonregulatory agency in the United States that establishes standards and best practices across science and technology. NIST publishes a wide variety of guidance and best practices within the field of information technology, including cybersecurity. Within the field of cybersecurity, the special publication (SP) 800 series documents and

the Risk Management Framework and Cybersecurity Framework are some of the industry's most widely adopted and referenced materials.

International Organization for Standardization (ISO)

The International Organization for Standardization (ISO) manages and publishes a cybersecurity framework called ISO 27k. The 27k framework was established in 2005, revised in 2013, and revised again in 2018. ISO 27k includes over a dozen standards, including 27002, which defines security controls; 27017/27018 for cloud security; 27701, which focuses on personal data and privacy; and many others.

Unlike the NIST framework, the ISO 27001 Information Security Management standard cannot be obtained free of charge. More information about the ISO information security management standard can be obtained via <https://www.iso.org/standard/27001>.

The acronym for ISO can be a source of confusion. Due to its international scope, the International Organization for Standardization translates into many different languages and requires many acronyms. To address this, ISO is used and reflects the Greek word isos which means "equal."

Copyright © CompTIA, Inc. All rights reserved.